



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Laboratorio di Sicurezza Informatica

LAB: VA ed enumeration

Marco Prandini

Dipartimento di Informatica – Scienza e Ingegneria

Qualche richiamo di reti IP

- **Associazione univoca indirizzo → sistema (*host*)**
 - (non è imposto il contrario → *multi-homed host*)
- **Indirizzi IPv4: 32 bit divisi in 4 byte, normalmente rappresentati con 4 numeri in base 10 separati da punti (*dotted decimal notation*)**
 - Esempio: 137.204.59.1
- **Ogni indirizzo fa parte di una rete (*subnet*) che inizia da un indirizzo di *network***
- **In origine l' estensione era implicita, ora è specificata da una *netmask***
 - Una subnet logica coincide con una LAN fisica
 - Per instradare un pacchetto verso la destinazione non serve considerare il suo indirizzo, basta la subnet cui appartiene

Reti class-based

Originariamente sono state definite *classi* di indirizzi, ovvero raggruppamenti da usare per i sistemi di una rete locale, in cui i byte erano rigidamente divisi tra **network id** e **host id**:

- 128 reti di Classe A (contenenti fino a 16 milioni di host circa):
 - indirizzi da 0.*.*.* a 127.*.*.*
- 16.384 reti di Classe B (contenenti fino a 65000 host circa):
 - indirizzi da 128.0.*.* a 191.255.*.*
- 2.097.152 reti di Classe C (contenenti fino a 254 host):
 - indirizzi da 192.0.0.* a 223.255.255.*
- Gli indirizzi da 224.*.*.* a 239.*.*.* sono riservati al *multicast*
- Gli indirizzi da 240.*.*.* a 255.*.*.* sono riservati a usi futuri

CIDR

- Poche classi di dimensioni fissate = spreco di indirizzi
- Soluzione: CIDR (*classless inter-domain routing*)
- Con classless-IP gli indirizzi sono visti come una stringa di 32 bit divisa in net-id e host-id in un punto arbitrario, anzichè per byte.

- Unico vincolo (ovvio): la dimensione di una rete è potenza di 2 (in questo esempio $2^6 = 64$ indirizzi)

144 . 156 . 166 . 151
1 0 0 1 0 0 0 0 1 0 0 1 1 1 0 0 1 0 1 0 0 1 1 0 1 0 0 1 0 1 1 1
26 bit net-id 6 bit host-id

- Una rete locale è identificata per mezzo di un *network address* e di una *netmask*, noti a tutti gli host che ne fanno parte.

Netmask, network, broadcast

- Serve un modo per specificare dove cade la divisione
- La *netmask* è un valore di 32 bit composto da
 - tanti “1” quanti sono i bit che identificano la subnet, seguiti da
 - tanti “0” quanti sono i bit che specificano l'host al suo interno
 - Nell'esempio precedente:
11111111.11111111.11111111.11000000 = 255.255.255.192
- Due valori in ogni subnet hanno un significato speciale e non possono essere usati per indirizzare un host:
 - Network address (ottenuto mettendo a 0 tutti i bit dell'host-id)
 - **10010000.10011100.10100110.10000000** = 144.156.166.128
 - Broadcast (ottenuto mettendo a 1 tutti i bit dell'host-id)
 - **10010000.10011100.10100110.10111111** = 144.156.166.191

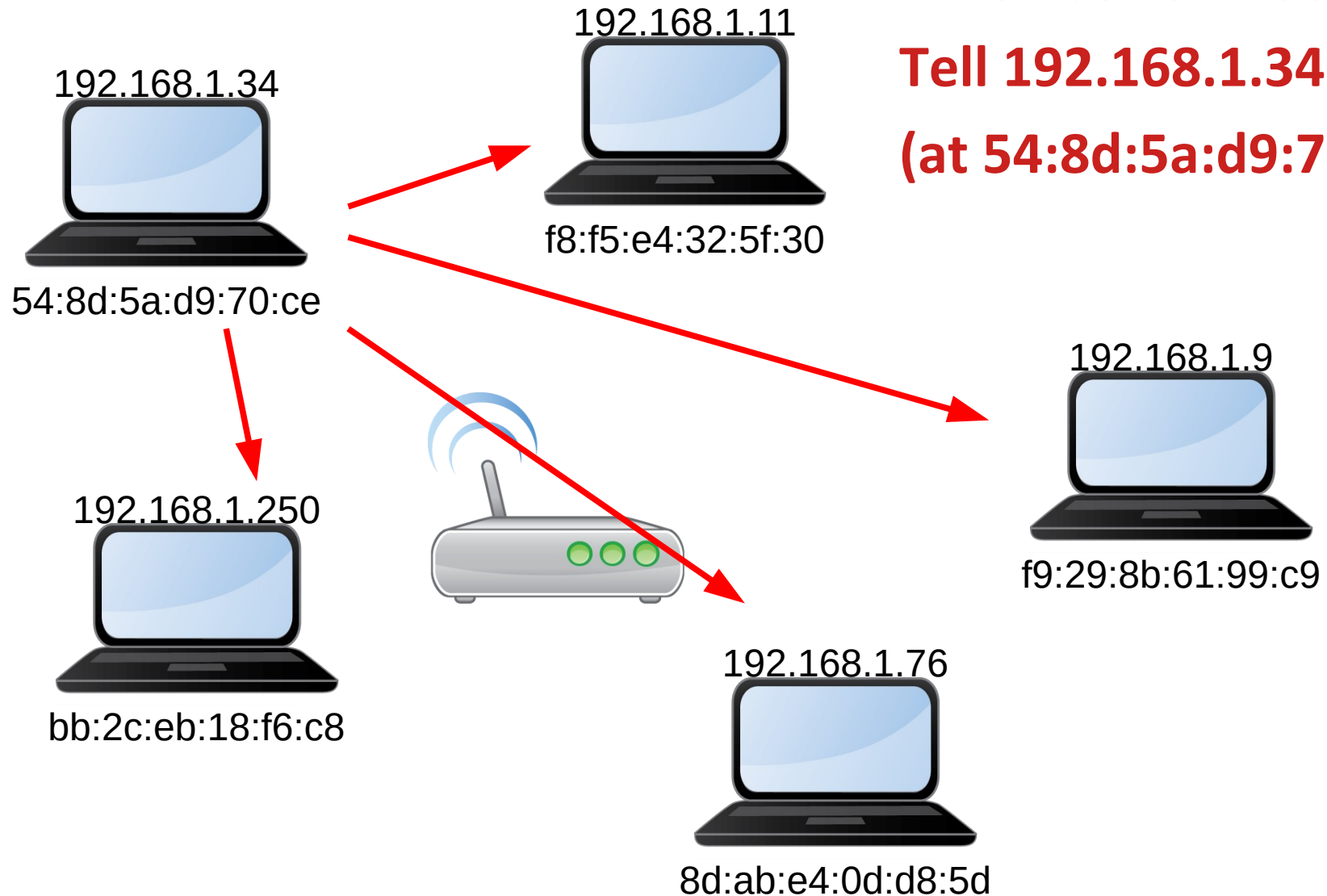
Raccolta di informazioni – IP blocks

- La conoscenza dei dettagli organizzativi o di pochi indirizzi IP validi può permettere di espandere la conoscenza
 - agli interi blocchi allocati all'obiettivo
 - ad altri blocchi non evidentemente collegati
- Esempio
 - da www.unibo.it riuscite a risalire a tutte le reti degli enti di ricerca e delle università italiane?
 - hint: strumenti di ricerca [RIPE](#)

Doppio indirizzamento nella LAN/subnet!

- Ogni dispositivo su Internet ha un indirizzo IP
 - è quello usato da qualsiasi applicazione, che affida il traffico allo stack di rete del sistema operativo
- ... ma il trasporto fisico avviene sulla LAN, dove i dispositivi si riconoscono dal MAC address
- Come tradurre un indirizzo nell'altro?
→ **Address Resolution Protocol (ARP – RFC 826)**
- Ricordiamoci se siamo già sulla rete locale da enumerare

ARP request - broadcast



**Who has 192.168.1.76?
Tell 192.168.1.34
(at 54:8d:5a:d9:70:ce)**

Assessment dall'interno: file e socket accessibili

■ **lsof** lists open files

- TCP and UDP sono solo namespace differenti

```
# lsof -i -n | egrep 'COMMAND|LISTEN|UDP'
```

COMMAND	PID	USER	FD	TYPE	DEVICE	SIZE	NODE	NAME
sshd	2317	root	3u	IPv6	6579		TCP	*:ssh (LISTEN)
xinetd	2328	root	5u	IPv4	6698		TCP	*:auth (LISTEN)
sendmail	2360	root	3u	IPv4	6729		TCP	127.0.0.1:smtp (LISTEN)

- provate **lsof | grep '(deleted)'**

Assessment dall'interno: punti di accesso esposti via rete

- **netstat** mostra lo stato delle socket Unix e di rete
 - di default, già connesse a un altro endpoint
 - opzione **-l** : listening
 - opzione **-a** : entrambe le categorie
 - altre opzioni utili
 - **-p** processo in ascolto
 - **-n** output numerico
 - **-t** tcp socket
 - **-u** udp socket
- **ss** è il rimpiazzo più recente, però non è SELinux-aware

netstat sample output

Active Internet connections (servers and established)

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	0.0.0.0:2049	0.0.0.0:*	LISTEN	-
tcp	0	0	0.0.0.0:993	0.0.0.0:*	LISTEN	3457/inetd
tcp	0	0	0.0.0.0:901	0.0.0.0:*	LISTEN	3457/inetd
tcp	0	0	0.0.0.0:904	0.0.0.0:*	LISTEN	11325/rpc.mountd
tcp	0	0	0.0.0.0:3689	0.0.0.0:*	LISTEN	11438/mt-daapd
tcp	0	0	127.0.0.1:3306	0.0.0.0:*	LISTEN	20600/mysqld
tcp	0	0	0.0.0.0:3690	0.0.0.0:*	LISTEN	11441/mt-daapd
tcp	0	0	0.0.0.0:139	0.0.0.0:*	LISTEN	3717/smbd
tcp	0	0	0.0.0.0:110	0.0.0.0:*	LISTEN	3457/inetd
tcp	0	0	0.0.0.0:143	0.0.0.0:*	LISTEN	3457/inetd
tcp	0	0	0.0.0.0:111	0.0.0.0:*	LISTEN	2953/portmap
tcp	0	0	0.0.0.0:6001	0.0.0.0:*	LISTEN	14660/Xrealvnc
tcp	0	0	0.0.0.0:113	0.0.0.0:*	LISTEN	3457/inetd
tcp	0	0	137.204.58.80:993	137.204.58.138:51929	ESTABLISHED	8190/imapd

Nmap

- **Software open-source per network discovery e security auditing.**
- **Include un potente motore di port scan, con test di vulnerabilità e logiche di discovery incluse di default.**
- **Per range piuttosto grandi con subnet di classe B esistono altri tool più performanti e meno invasivi, come masscan, che aiutano nell'identificazione di servizi e porte aperte ma che non offrono le potenzialità di nmap**

Nmap

- Come prima cosa facciamo un host discovery per scoprire l'ip della macchina vulnerabile sulla rete host-only
- Lanciamo:
`nmap --help`
Nmap 7.70 (<https://nmap.org>)
Usage: nmap [Scan Type(s)] [Options] {target specification}
- Per fare uno scan sulla rete invece lanciare:
`nmap -sn 192.168.56.0/24`
 -
 -
 - lista di ip che “rispondono”

Nmap

- A questo punto possiamo usare nmap per fare uno scan delle porte e i servizi disponibili
- Modalità più semplice e veloce con -sT (per TCP)
 - `nmap -T $IP`
 - Ci fidiamo della rilevazione dei servizi solo sulla base del numero di porta?
- Modalità più comune con -A “all”:
 - `nmap -A $IP`
- Modalità più “invasiva” con salvataggio dell’output si più formati.
 - `nmap -sC -sV -oA output_porte.txt $IP`

Approfondire l'analisi

- Nmap riporta informazioni interessanti sui servizi
- L'analisi di come i servizi effettivamente rispondono deve essere fatta con tool interattivi
 - Manualmente, con una connessione basilare TCP/IP
 - `nc`
 - `openssl s_client`
 - Manualmente, coi client nativi
 - `smbclient`, `psql`, `mariadb`, `ftp`, `ssh`, ...
- Vale la pena provarli per vedere “cosa c'è sotto”!
- Ovviamente sono analisi automatizzabili
 - Pentesting tool specifici di ogni servizio
 - `smbmap`, `sqlmap`, ...
 - Piattaforme di VA

Greenbone Security Assistant

- In parallelo alla ricerca manuale di percorsi di accesso, si può avviare un Vulnerability Assessment
- Per avviare OpenVAS / GSA in Parrot
 - Entrare nella directory `~/greenbone-community-container`
 - Lanciare `docker compose up`
 - La prima volta, attendere la sincronizzazione dei feed (anche ore!)
 - Se firefox è chiuso, dovrebbe aprirsi sulla pagina giusta
 - Se è già aperto o dà errore, inserire a mano `https://127.0.0.1:9392`
 - Le credenziali sono `admin:admin`
 - Un tutorial per l'uso dell'interfaccia (attenzione, gli indirizzi e le credenziali sono ovviamente diversi) è stato pubblicato dall'INFN

https://agenda.infn.it/event/32540/contributions/179667/attachments/97880/135451/04-lanzi-greenbone-interfaccia_web.pdf

- Create un task → richiede la definizione di un target → osservate come sia possibile definire IP e porte → avendo già il risultato di nmap si può rendere più mirato ed efficiente il lavoro di GSA

Account brute forcing

- Una volta individuati host che espongono servizi autenticati, l'enumeration potrebbe proseguire
 - tentando di rilevare account validi
 - tentando di indovinare o scoprire le credenziali di accesso (questo passaggio è oltre il concetto di enumeration)
- Guessing
 - liste di nomi noti e password leaked (stile OSINT)
 - liste di nomi e password comunque probabili
- Brute forcing
 - algoritmi di generazione nomi e soprattutto password
 - Iniziamo vedendo come farlo dall'esterno, poi introdotti i concetti di autenticazione vedremo come la situazione migliora dall'interno

Guessing e dictionary attack

■ Esplorazione

- Nmap ha restituito molti servizi, la maggior parte è progettata per essere amministrata da remoto
- In un processo di PT, li si esplorano sistematicamente
- C'è qualcosa di insolito che incuriosisce?
 - Usiamo un tool per tentare combinazioni di username e password
<https://github.com/vanhauser-thc/thc-hydra>

■ Wordlists

- Sulla VM Parrot avete già disponibili liste di parole comunemente usate come username e password

Guessing e dictionary attack

■ Attacco

- Lanciando Hydra, viene avviato in modalità guidata, è sufficiente rispondere alle domande
- Al termine mostrerà la riga di comando composta in questo modo, per poterla riutilizzare senza bisogno del “wizard” interattivo

Welcome to the Hydra Wizard

Facciamo un po' di guessing per limitare il numero di tentativi:
tentiamo un nome utente che riteniamo probabile

Enter the service to attack (eg: ftp, ssh, http-post-form): **ssh**

Enter the target to attack (or filename with targets): **192.168.56.101**

Enter a username to test or a filename: **guest**

Enter a password to test or a filename: **/usr/share/wordlists/rockyou.txt**

If you want to test for passwords (s)ame as login, (n)ull or (r)everse login, enter these letters without spaces (e.g. "sr") or leave empty otherwise: **[INVIO]**

Port number (press enter for default): **23**

The following options are supported by the service module: **[INVIO]**

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) starting at 2025-03-06 08:37:49

Help for module ssh:

=====

The Module ssh does not need or support optional parameters

If you want to add module options, enter them here (or leave empty): **[INVIO]**

The following command will be executed now:

```
hydra -l guest -P /usr/share/wordlists/rockyou.txt -u -s 23 192.168.56.101 ssh
```

Il wizard riconosce che qui è stato inserito un path completo e quindi leggerà le password dal file e le tenterà una dopo l'altra: dictionary attack

Do you want to run the command now? [Y/n] **[INVIO = Y]**

“Enumerare” le password dall’interno

- **L’enumerazione dall’esterno è limitata**
 - Lenta nel migliore dei casi
 - Facile da individuare e bloccare
- **Ricordiamo come sono memorizzate le password**
- **Cosa potrei fare disponendo degli hash?**
 - memento: l’hash non è invertibile, ma...
 - si può provare una password-candidata dopo l’altra, calcolare l’hash, e verificare se coincide con uno di quelli disponibili
 - velocità limitata solo dalla potenza di calcolo disponibile

John the ripper

<https://www.openwall.com/john/>

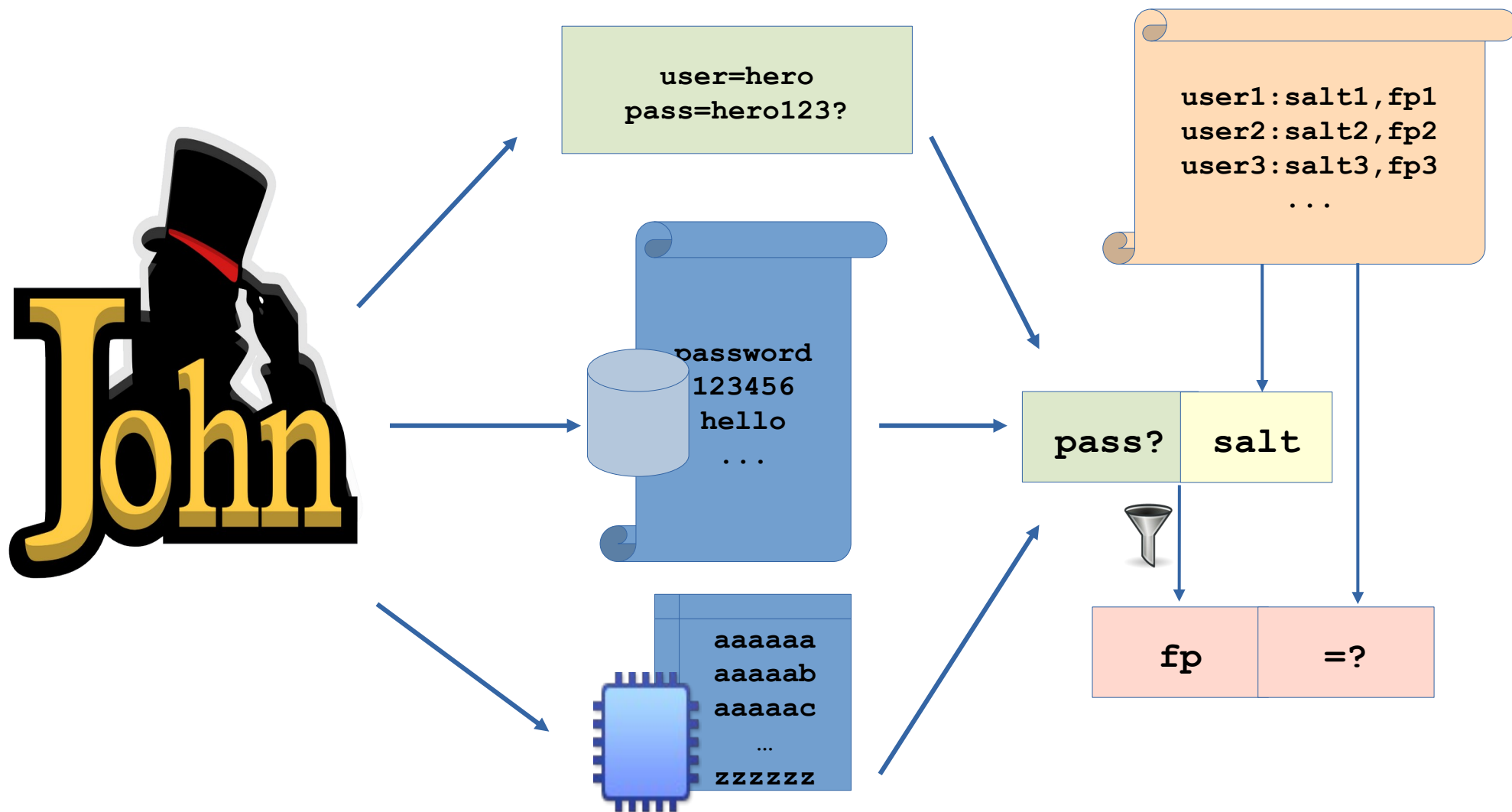


```
(root@kali)-[~/cupp]
# cat credentials
```

```
kali:$y$j9T$PxSSpGq2JjuTlfK/cVRYN1$NLNTIjPlhbuASQfbekQQbYY17bFyFn1DooCwntcELuB:1000:1000:,,,:/home/kali:/usr/bin/zsh
caine:$y$j9T$IBGz621Z6SblwNCHqM6/L0$kuzCWKQOUGL9Hztjz1BoTPyU7NFbJJJCZbludwAKPE8:1001:1001:Sir Michael Caine,,,:/home/caine:/bin/bash
tooeasy:$y$j9T$h68oFxoQIiUuL/c7DVdMh1$i6Zgb.MDjW2Lp4NRwOoD2ujYQLMdKzQjrRLmRltxGjB:1002:1002:Vado Di Fretta,,,:/home/tooeasy:/bin/bash
hero:$y$j9T$2lZszq43eNuDURt.Ce3Hf1$Qbm77CwPfZbHwoihaiYv3/QpajvXqlncHGyn7XRHPcC:1003:1003:Volà Alto,,,:/home/hero:/bin/bash
```

nome utente : impronta : dati personali : cartella di lavoro : interfaccia utente

John the ripper – tre modi di enumerazione



John the ripper – single mode

```
(root@kali) - [~/cupp]
john --single -format=crypt credentials
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:30 14.20% (ETA: 17:39:59) 0g/s 142.0p/s 142.0c/s 142.0C/s difretta8..tvado*
kali kali (kali)
1g 0:00:00:52 18.49% (ETA: 17:41:09) 0.01916g/s 141.5p/s 141.6c/s 141.6C/s Volaj..Altop
1g 0:00:01:52 35.32% (ETA: 17:41:45) 0.008923g/s 137.8p/s 137.9c/s 137.9C/s Hcainecaine..Mmichaelsir
1g 0:00:03:29 58.90% (ETA: 17:42:22) 0.004776g/s 136.1p/s 136.1c/s 136.1C/s Altohero95..Herovola02
1g 0:00:05:04 77.48% (ETA: 17:43:01) 0.003282g/s 135.1p/s 135.1c/s 135.1C/s Frettavado33..Vado37
Almost done: Processing the remaining buffered candidate passwords, if any.
1g 0:00:06:55 DONE (2025-04-09 17:43) 0.002406g/s 134.6p/s 135.0c/s 135.0C/s vadotooeasy1902..fdi1900
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```


John the ripper – wordlist

```
(root@kali)-[~/cupp]
# ls -l /usr/share/wordlists
total 52108
lrwxrwxrwx 1 root root 26 Mar 7 07:14 amass → /usr/share/amass/wordlists
lrwxrwxrwx 1 root root 25 Mar 7 07:14 dirb → /usr/share/dirb/wordlists
lrwxrwxrwx 1 root root 30 Mar 7 07:14 dirbuster → /usr/share/dirbuster/wordlists
lrwxrwxrwx 1 root root 35 Mar 7 07:14 dnsmap.txt → /usr/share/dnsmap/wordlist_TLAs.txt
lrwxrwxrwx 1 root root 41 Mar 7 07:14 fasttrack.txt → /usr/share/set/src/fasttrack/wordlist.txt
lrwxrwxrwx 1 root root 45 Mar 7 07:14 fern-wifi → /usr/share/fern-wifi-cracker/extras/wordlists
lrwxrwxrwx 1 root root 28 Mar 7 07:14 john.lst → /usr/share/john/password.lst
lrwxrwxrwx 1 root root 27 Mar 7 07:14 legion → /usr/share/legion/wordlists
lrwxrwxrwx 1 root root 46 Mar 7 07:14 metasploit → /usr/share/metasploit-framework/data/wordlists
lrwxrwxrwx 1 root root 41 Mar 7 07:14 nmap.lst → /usr/share/nmap/nselib/data/passwords.lst
-rw-r--r-- 1 root root 53357329 May 12 2023 rockyou.txt.gz
lrwxrwxrwx 1 root root 39 Mar 7 07:14 sqlmap.txt → /usr/share/sqlmap/data/txt/wordlist.txt
lrwxrwxrwx 1 root root 25 Mar 7 07:14 wfuzz → /usr/share/wfuzz/wordlist
lrwxrwxrwx 1 root root 37 Mar 7 07:14 wifite.txt → /usr/share/dict/wordlist-probable.txt
```

```
(root@kali)-[~/cupp]
# john --format=crypt -w=rockyou.txt --credentials
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Remaining 3 password hashes with 3 different salts
Cost 1 (algorithm [1:descript 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
superman = (hero)
lg 0:00:00:14 DONE (2025-04-09 17:59) 0.06798g/s 67.98p/s 142.4c/s 142.4C/s marie1..cassandra
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```


John the ripper + cupp = targeted attack

Informazioni

Sir Michael Caine, nato Maurice Joseph Micklewhite, è un attore britannico. Apparso in oltre cento pellicole e attivo su grande schermo dal 1956, è uno dei volti più noti del cinema britannico, grazie ... [Wikipedia](#)

Nascita: 14 marzo 1933 (età 92 anni), [St Olave's Hospital, Londra](#)

Coniuge: [Shakira Caine](#) (s. 1973), [Patricia Haines](#) (s. 1954–1958)

Altezza: 1,88 m

Figli: [Natasha Caine](#), [Dominique Caine](#)

Candidature: [Oscar al miglior attore](#) · [Vedi altro](#)

_973731973

...

ahsataN0173

...

maurice*!!

michael.txt
10500 password

cupp.py!

{oo}
(-)
||-|| *

```
# Common  
# User  
# Passwords  
# Profiler
```

```
[ Muris Kurgas | jorgan@remote-exploit.org ]  
[ Mebus | https://github.com/Mebus/ ]
```

```
[+] Insert the information about the victim to make a dictionary  
[+] If you don't know all the info, just hit enter when asked! ;)
```

```
> First Name: Michael  
> Surname: Caine  
> Nickname: Maurice  
> Birthdate (DDMMYYYY): 14031933  
  
> Partners) name: Shakira  
> Partners) nickname: Patricia  
> Partners) birthdate (DDMMYYYY): 23021947  
  
> Child's name: Natasha  
> Child's nickname: Dominique  
> Child's birthdate (DDMMYYYY): 01011973  
  
> Do you want to add some key words about the victim? Y/[N]:  
> Do you want to add special chars at the end of words? Y/[N]: Y  
> Do you want to add some random numbers at the end of words? Y/[N]: Y  
> Leet mode? (i.e. leet = 1337) Y/[N]: N
```

John the ripper + cupp = targeted attack

```
(root@kali)-[~/cupp]
# john --format=crypt -w=michael.txt credentials
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Remaining 2 password hashes with 2 different salts
Cost 1 (algorithm [1:descript 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
arikahS_47 (caine)
1g 0:00:02:01 DONE (2025-04-09 18:04) 0.008238g/s 86.50p/s 130.0c/s 130.0C/s shakira@8*..shakira_947
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

John the ripper – incremental

```
(root@kali)-[~/cupp]
# john --format=crypt --incremental credentials
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Remaining 1 password hash
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:01 0.04% (ETA: 18:55:03) 0g/s 152.3p/s 152.3c/s 152.3C/s bama.. juda
0g 0:00:00:03 0.11% (ETA: 19:02:59) 0g/s 148.1p/s 148.1c/s 148.1C/s muan.. josa
0g 0:00:00:04 0.15% (ETA: 19:00:43) 0g/s 147.6p/s 147.6c/s 147.6C/s stfd.. luvy
0g 0:00:00:06 0.21% (ETA: 19:02:59) 0g/s 147.0p/s 147.0c/s 147.0C/s pini.. sese
0g 0:00:00:07 0.23% (ETA: 19:05:52) 0g/s 146.8p/s 146.8c/s 146.8C/s stay.. poee
0g 0:00:00:09 0.29% (ETA: 19:06:23) 0g/s 146.4p/s 146.4c/s 146.4C/s adam.. abcs
abcd (tooeasy)
1g 0:00:00:09 DONE (2025-04-09 18:15) 0.1017g/s 146.4p/s 146.4c/s 146.4C/s adam.. abcs
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```